Protéger : identités, réseau, données

CL-SECU — Jour 1 (version 2 jours)

Aujourd'hui, on ferme les portes : qui a le droit d'entrer, par où, et ce qu'on trouve derrière.

Utopios® Tous droits réservés

Objectifs de la journée

À la fin de la journée, vous saurez :

- **Expliquer** trois incidents cloud réels et la **responsabilité partagée**.
- **Écrire** une politique IAM au moindre privilège et **prouver** ce qu'elle autorise.
- **Détecter et corriger** un port SSH ouvert à tout Internet.
- **Fermer** un bucket au public, et **partager** un fichier sans l'exposer.
- **Ranger** un secret dans un coffre, et dire comment une application le lit **sans clé**.

Tout se fait sur **AWS**, dans **AWS CloudShell** : rien à installer. Azure apparaît en parallèle, et en **bonus** pour les plus rapides.

Utopios® Tous droits réservés

Plan de la journée

Horaire	Contenu	Pratique
9h00	**1. Pourquoi la sécurité cloud** : 3 incidents, responsabilité partagée	
9h30	Mise en route : AWS CloudShell	✏️ Exercice 0
9h45	**2. Identités** : moindre privilège, MFA, rôles plutôt que clés	
10h45	Une politique IAM au plus juste, prouvée	✏️ Exercice 1
11h20	**3. Réseau** : security groups, le port 22 ouvert au monde	
12h00	Créer l'erreur, la détecter, la corriger	✏️ Exercice 2
13h30	**4. Données et secrets** : chiffrement, accès public, coffres	
14h15	Un bucket durci, un secret dans Parameter Store	✏️ Exercice 3
15h20	Correction collective, rattrapage, **bonus Azure**	
16h30	Récap et quiz	

Utopios® Tous droits réservés

1. Pourquoi la sécurité cloud

Trois incidents réels, une même leçon

Utopios® Tous droits réservés

Trois incidents réels

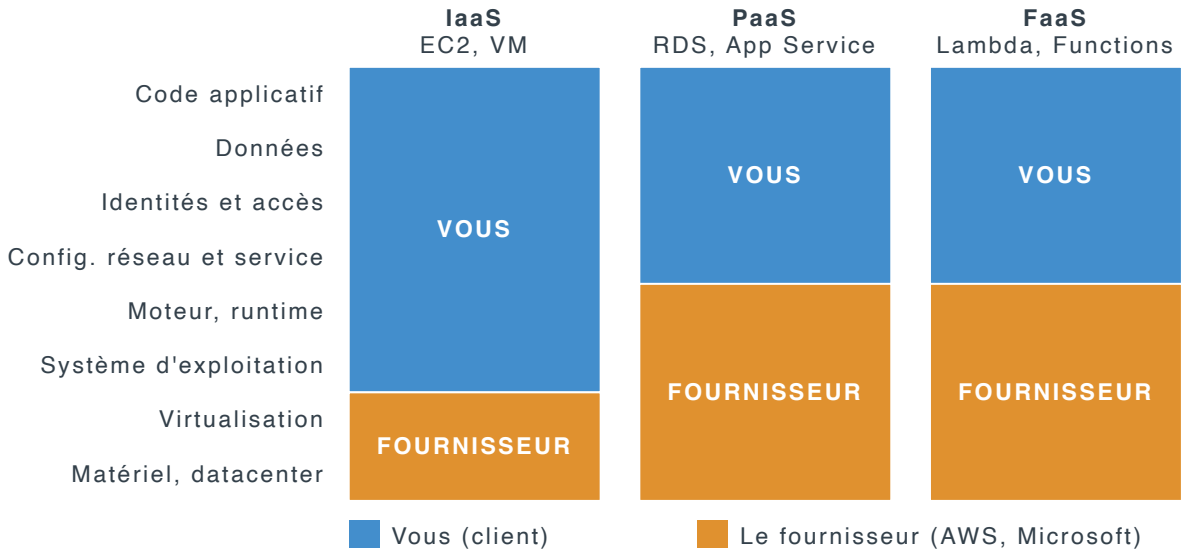
	Capital One (2019)	Buckets S3 publics (2017)	Clé AWS publiée sur GitHub
Les faits	Une faille du pare-feu applicatif livre à l'attaquant les identifiants du **rôle** d'un serveur EC2.	Des buckets lisibles par **tout Internet** : environ 198 millions d'électeurs américains exposés.	Une clé `AKIA…` poussée dans un dépôt public est trouvée par des robots en **quelques minutes**.
La suite	Ce rôle peut lire de nombreux buckets : les données d'environ **100 millions** de clients sont copiées.	Des scanners automatiques téléchargent tout, sans authentification.	Des instances sont lancées pour miner de la cryptomonnaie : une facture énorme en une nuit.
Ce qui l'aurait évité	un rôle au **moindre privilège**	le **blocage de l'accès public**	**aucune clé** : des rôles et un coffre

Point commun : le fournisseur n'a **pas** été piraté. À chaque fois, c'est une **configuration** du client : une identité trop large, une case « public » restée ouverte, une clé en clair.

Utopios® Tous droits réservés

La responsabilité partagée

Le fournisseur sécurise **le** cloud ; vous sécurisez ce que vous y **mettez** et ce que vous y **configurez**.



« Managé » ne veut pas dire « sécurisé sans rien faire » : la frontière se déplace, elle ne disparaît pas

Quel que soit le modèle, quatre sujets restent **toujours** à vous : **identités**, **réseau**, **données**, **secrets**. C'est le programme de la journée.

Utopios® Tous droits réservés

✏️ Exercice 0 — Mise en route

Fichier : `exercices/15-cl-secu-2j/exercice-0-mise-en-route.md` · 15 min · rien à installer

1. Connectez-vous à la console AWS avec votre utilisateur `userN`, région **Europe (Paris) eu-west-3**.
2. Ouvrez **AWS CloudShell** (icône `>_`) : un terminal déjà connecté à votre compte.
3. Collez le bloc de vérification. Résultat attendu :

```
Utilisateur : user7 | Compte : 639962416620 | Région : eu-west-3
OK : identité AWS reconnue (user7)
```

Les règles de **tous** les exercices :

- chaque bloc commence par `# [AWS CloudShell]` et recalcule vos variables : rien à remplacer ;
- copiez-collez chaque bloc **en entier** : il affiche `OK` ou `ERREUR` ;
- le compte est **partagé** : ne touchez qu'aux ressources qui portent votre nom (`secu-userN-…`).

Utopios® Tous droits réservés

2. Identités

Qui a le droit de faire quoi, sur quoi

Utopios® Tous droits réservés

Le moindre privilège, écrit en JSON

Sur AWS, une identité (utilisateur, groupe, rôle) n'a **aucun** droit tant qu'on ne lui attache pas une **politique**. Le **moindre privilège** : les droits nécessaires à la tâche, pas un de plus.

```
{
  "Sid": "LireLesObjets",
  "Effect": "Allow",
  "Action": "s3:GetObject",
  "Resource": "arn:aws:s3:::$BUCKET/*"
}
```

Extrait de l'exercice 1 : lire les objets d'**un seul** bucket.

- `Effect` : autoriser (`Allow`) ou refuser (`Deny`).
- `Action` : quel appel d'API.
- `Resource` : sur quoi, un **ARN** précis plutôt que `*`.
- `Condition` (facultatif) : MFA, HTTPS…

Deny by default : tout ce qui n'est pas autorisé est refusé (`implicitDeny`). Un `Deny` explicite l'emporte **toujours** sur un `Allow`.

Utopios® Tous droits réservés

MFA, et des rôles plutôt que des clés

MFA (authentification multifacteur) : un mot de passe **et** un code à usage unique (application sur téléphone ou clé physique). Un mot de passe volé ne suffit plus. À activer en priorité sur les comptes administrateurs.

	Clé d'accès (`AKIA…` + secret)	Rôle IAM
Durée de vie	illimitée, jusqu'à révocation	identifiants **temporaires** (minutes à heures)
Où elle finit	fichier, `.env`, dépôt Git…	nulle part : rien à stocker
Si elle fuit	accès durable et silencieux	inutilisable après expiration

- **Une application** reçoit un **rôle** attaché à sa ressource (instance EC2, fonction Lambda).
- **Un humain** passe par la console avec MFA. CloudShell n'a besoin d'**aucune** clé : il réutilise votre session.

Utopios® Tous droits réservés

Le parallèle Azure : RBAC

Sur Azure, on n'écrit généralement pas de politique : on **attribue un rôle** à une identité **sur une portée**. Le droit est hérité par tout ce que contient la portée.

```
abonnement  >  groupe de ressources (rg-stagiaire07)  >  ressource
```

AWS	Azure
politique IAM écrite en JSON	rôle intégré choisi : Reader, Contributor…
`Resource` : un ARN	la **portée** de l'attribution
rôle IAM attaché à une ressource	**identité managée**

Quel est **votre** rôle sur votre groupe de ressources ? Réponse dans le bonus Azure de l'exercice 1.

Utopios® Tous droits réservés

✏️ Exercice 1 — Le moindre privilège, prouvé

Fichier : `exercices/15-cl-secu-2j/exercice-1-moindre-privilege.md` · 35 min · rien n'est créé dans le compte

1. **Faire juger** une politique trop large par **IAM Access Analyzer**.
2. **Écrire** la politique d'un script qui doit seulement lister et lire **votre** bucket.
3. **Prouver** ce qu'elle autorise avec le **simulateur de politiques**, sans l'attacher à personne.

Ce qu'Access Analyzer a relevé en test :

```
|  SECURITY_WARNING |  PASS_ROLE_WITH_STAR_IN_RESOURCE  |
|  ERROR |  INVALID_ACTION  |
```

- `iam:PassRole` sur `*` : on peut confier **n'importe quel** rôle à un service, y compris un rôle administrateur.
- `s3:GetObjet` (faute de frappe) : IAM l'aurait accepté… et rien n'aurait été autorisé.

Bonus Azure : comparer ce que permettent Reader, Contributor et Storage Blob Data Reader.

Utopios® Tous droits réservés

3. Réseau

Tout fermer par défaut, n'ouvrir que le strict nécessaire

Utopios® Tous droits réservés

Security groups : deny by default

Un **security group** est un **pare-feu virtuel** attaché à une instance, une base de données…

- **Deny by default** : tout trafic entrant est refusé, sauf ce qu'une règle autorise.
- Une bonne règle = **un port précis** + **une source précise** (`/32` = une seule adresse).
- `0.0.0.0/0` = toutes les adresses IPv4, donc **tout Internet**.

SSH (port 22) donne un terminal administrateur. Ouvert à `0.0.0.0/0`, il est sondé en permanence par des robots.



Compte AWS de la formation, région eu-west-3 — 80 groupes de sécurité au total

Mesuré en test : plus des deux tiers des groupes de sécurité du compte exposent SSH à tout Internet

Utopios® Tous droits réservés

Mieux : ne pas ouvrir le port 22 du tout

Restreindre la source à votre adresse (`/32`) est la correction **minimale**. Mieux : administrer la machine **sans** port entrant ouvert sur Internet.

Solution	Principe
Session Manager (AWS Systems Manager)	un agent sur l'instance ouvre une connexion **sortante** vers AWS ; terminal depuis la console, droits IAM, sessions tracées
EC2 Instance Connect Endpoint	un point d'accès dans le VPC : SSH vers une instance **sans adresse IP publique**, autorisé par IAM
Azure Bastion (parallèle Azure)	SSH ou RDP depuis le portail, en HTTPS ; la VM n'a pas d'IP publique. 💰 Facturé à l'heure

L'accès devient une question d'**identité** (qui a le droit ?) plutôt que d'**adresse réseau**.

Utopios® Tous droits réservés

✏️ Exercice 2 — Le port SSH ouvert au monde

Fichier : `exercices/15-cl-secu-2j/exercice-2-port-ssh-ouvert.md` · 30 min

1. **Reproduire l'erreur** sur `secu-userN-sg`, un groupe **vide** : port 22 ouvert à `0.0.0.0/0`.
2. **Détecter** dans tout le compte, par une requête plutôt qu'à l'œil :

```
# [AWS CloudShell]
export AWS_REGION=eu-west-3
aws ec2 describe-security-groups --filters Name=ip-permission.from-port,Values=22 Name=ip-
permission.cidr,Values=0.0.0.0/0 --query "SecurityGroups[].[GroupId,GroupName]" --output text | head -n 20
```

3. **Corriger** : n'autoriser que l'adresse de votre CloudShell, en `/32`.

⚠️ Ne modifiez **que** le groupe qui porte votre nom. Les autres, on les **observe**.

Bonus Azure : le même scénario avec un NSG (le security group d'Azure).

Utopios® Tous droits réservés

4. Données et secrets

Chiffrer, fermer au public, ranger les secrets

Utopios® Tous droits réservés

Chiffrer au repos et en transit

- **Au repos** : la donnée stockée. S3 chiffre tout nouvel objet **par défaut** depuis 2023 (`AES256`). Les clés sont gérées par **KMS** (*Key Management Service*).
- **En transit** : la donnée qui circule, protégée par **TLS** (le « S » de HTTPS).

Imposer HTTPS : une **politique de bucket** qui **refuse** toute requête non chiffrée. Un `Deny` l'emporte sur tout `Allow`.

```
{
  "Sid": "RefuserSansHTTPS",
  "Effect": "Deny",
  "Principal": "*",
  "Action": "s3:*",
  "Resource": ["arn:aws:s3:::$BUCKET", "arn:aws:s3:::$BUCKET/*"],
  "Condition": { "Bool": { "aws:SecureTransport": "false" } }
}
```

⚠️ Le chiffrement au repos ne protège **pas** d'un accès public : S3 déchiffre pour quiconque a le droit de lire… y compris « tout le monde ».

Utopios® Tous droits réservés

Fermer l'accès public : les garde-fous

Un **droit** dit ce qu'une identité peut faire. Un **garde-fou** fixe une limite que **personne** ne franchit, administrateurs compris.

Garde-fou	S'applique à	Exemple
Blocage de l'accès public S3	un bucket, ou tout le compte	actif par défaut sur tout nouveau bucket depuis 2023
SCP (*Service Control Policy*, AWS Organizations)	des comptes AWS entiers	interdire toute région hors `eu-west-3`
Azure Policy (parallèle Azure)	un abonnement, un groupe de ressources	vos groupes `rg-stagiaireNN` : régions et tailles de VM imposées

Mesuré en test : S3 refuse une politique de bucket publique, avec un `AccessDenied` qui cite `BlockPublicPolicy`.

Un bon garde-fou rend l'erreur **impossible**, pas seulement interdite.

Utopios® Tous droits réservés

Partager sans rendre public : l'URL présignée

Une **URL présignée** est un lien vers **un** objet, signé avec vos identifiants, valable une **durée limitée**. Qui détient le lien peut s'en servir jusqu'à expiration : durée courte, et on le traite comme un secret.

Résultat de l'exercice 3 :

```
OK : accès anonyme refusé (HTTP 403)
URL présignée (valable 5 minutes) : https://secu-user7-639962416620.s3.eu-west-3.amazonaws.com/rapport.csv?...
OK : l'URL présignée donne accès au fichier (HTTP 200)
OK : la même URL en HTTP (sans chiffrement) est refusée (HTTP 403)
```

- **403 en anonyme** : le bucket n'est pas public.
- **200 avec la signature** : l'accès est autorisé, pour ce fichier et pour 5 minutes.
- **403 en HTTP** : la politique `RefuserSansHTTPS` fait son travail.

Parallèle Azure : le **jeton SAS** (bonus de l'exercice 3).

Utopios® Tous droits réservés

Ranger les secrets dans un coffre

Un **secret** ouvre un accès : mot de passe, clé d'API, chaîne de connexion. Sa place n'est ni dans le code, ni dans Git, ni dans un `.env` : elle est dans un **coffre**, chiffré, accessible par identité, **versionné**.

	Parameter Store (`SecureString`)	Secrets Manager
Chiffrement	clé KMS	clé KMS
Versions	oui, avec l'auteur de chaque version	oui
Rotation automatique	non : à scripter	**oui**, intégrée
Coût	gratuit (paramètres standard)	💰 environ 0,40 $ par secret et par mois

Lire un `SecureString` **en clair** exige deux droits : `ssm:GetParameter` **et** `kms:Decrypt` sur la clé.

Parallèle Azure : **Key Vault** (secrets, clés de chiffrement, certificats).

Utopios® Tous droits réservés

Lire un secret… sans clé

Le piège : donner à l'application une clé d'accès pour lire le coffre. On n'a fait que **déplacer** le secret. La réponse : c'est la **plateforme** qui fournit l'identité.

```
Application (instance EC2, fonction Lambda…)
  │ 1. porte une identité attachée par la plateforme
  │ 2. reçoit des identifiants temporaires, renouvelés automatiquement
  ▼
Coffre (Parameter Store, Secrets Manager, Key Vault)
  │ 3. vérifie le droit de CETTE identité sur CE secret
  ▼
Valeur du secret, gardée en mémoire : jamais écrite dans un fichier
```

- **AWS** : un **rôle IAM** attaché à la ressource, limité à **ses** paramètres.
- **Azure** : une **identité managée**, créée et gérée par Azure pour la ressource, sans mot de passe à manipuler.

Utopios® Tous droits réservés

✏️ Exercice 3 — Des données qui ne fuient pas

Fichier : `exercices/15-cl-secu-2j/exercice-3-donnees-et-secrets.md` · 50 min

1. **Créer et inspecter** votre bucket `secu-userN-<numéro-de-compte>` : accès public bloqué, chiffrement.
2. **Imposer HTTPS** par une politique de bucket, puis déposer `rapport.csv`.
3. **Prouver** : anonyme 403, URL présignée 200, même URL en HTTP 403.
4. **Tenter l'erreur** : une politique publique… refusée par le garde-fou.
5. **Ranger un secret** dans Parameter Store : sans déchiffrement, une valeur illisible (`AQICA…`) ; avec `--with-decryption`, le mot de passe en clair.

Bonus Azure : un compte de stockage durci, un partage par jeton SAS.

De 15h20 à 16h30 : correction collective, rattrapage et bonus Azure de tous les exercices.

Utopios® Tous droits réservés

Récap des points clés

- Les incidents réels sont des **configurations** côté client. Identités, réseau, données et secrets restent **toujours** à vous.
- **IAM** : refus par défaut, un `Deny` gagne toujours ; le moindre privilège se **prouve** (Access Analyzer, simulateur).
- **MFA** pour les humains, **rôles** pour les applications : pas de clé longue durée.
- **Réseau** : deny by default ; jamais le port 22 ouvert au monde ; mieux, pas de port du tout (Session Manager).
- **Données** : chiffrées au repos et en transit, fermées au public par un **garde-fou**, partagées par URL présignée courte.
- **Secrets** : dans un coffre, lus par une identité (rôle IAM, identité managée), jamais avec une clé.

Utopios® Tous droits réservés

Quiz — questions 1 & 2

Q1. Vrai ou faux : avec un service managé comme RDS ou Lambda, la configuration des accès est à la charge du fournisseur. Justifiez.

Q2. Le simulateur de politiques répond `implicitDeny` pour `s3:PutObject` sur votre bucket. Que signifie ce résultat ?

Utopios® Tous droits réservés

Quiz — questions 3 & 4

Q3. Access Analyzer signale `PASS_ROLE_WITH_STAR_IN_RESOURCE` sur une politique. Quel est le risque ?

Q4. Un security group autorise le port 22 depuis `0.0.0.0/0`. Pourquoi est-ce dangereux ? Citez une façon d'administrer la machine sans ouvrir ce port.

Utopios® Tous droits réservés

Quiz — questions 5 & 6

Q5. Votre bucket est chiffré au repos (`AES256`). Est-il protégé si quelqu'un le rend public ? Quel mécanisme empêche qu'il le devienne ?

Q6. Une application doit lire un mot de passe rangé dans Parameter Store. Comment s'authentifie-t-elle sans qu'aucune clé ne soit stockée ?

Utopios® Tous droits réservés

À demain — Jour 2

Détecter et réagir

Aujourd'hui, vous avez fermé les portes. Demain, vous saurez **qui les a ouvertes** : journaux CloudTrail, réponse à une clé d'accès fuitée, vraies attaques vues par GuardDuty.

Question à garder en tête : le port 22 que vous avez ouvert ce matin, pourrez-vous retrouver **qui** l'a ouvert, **quand**, et **depuis où** ?

Utopios® Tous droits réservés

Détecter et réagir

CL-SECU — Jour 2 (version 2 jours)

Hier, on a fermé les portes. Aujourd'hui : savoir **qui les ouvre**, **réagir** quand ça arrive, et **mesurer** où en est le compte.

Utopios® Tous droits réservés

Objectifs de la journée

À la fin de cette journée, vous serez capable de :

- **Enquêter** dans CloudTrail : qui a fait quoi, quand, depuis où, et savoir ce que le journal **ne voit pas**.
- **Réagir avec méthode** à une clé d'accès fuitée : contenir sans détruire, vérifier, enquêter.
- **Expliquer** pourquoi la meilleure clé d'accès est celle qui n'existe pas.
- **Lire** une alerte GuardDuty et un audit de posture fondé sur le benchmark CIS.
- **Situer** RGPD, ISO 27001, SecNumCloud et la démarche DevSecOps.

Fil rouge : tout ce que vous avez construit hier, vous allez le **retrouver** dans les journaux.

Utopios® Tous droits réservés

Plan de la journée

Heure	Au programme
9h00	Correction du quiz du jour 1
9h15	**1. Journaliser** : CloudTrail, journal d'activité Azure
10h00	✏️ Exercice 4 — Qui a fait quoi ?
10h50	**2. Réagir** : la réponse à incident
11h30	✏️ Exercice 5 — Une clé a fuité (fin de l'enquête à 13h30)
13h50	**3. Surveiller** : 💻 démo GuardDuty et audit express
14h55	**4. Survol** : conformité, DevSecOps, alertes automatiques
15h45	Correction, rattrapage, bonus Azure
16h30	🧹 Nettoyage obligatoire
16h45	Synthèse du module et quiz

Pauses : 10h35, 12h15-13h30 (déjeuner), 14h40.

Utopios® Tous droits réservés

1. Journaliser

Qui a fait quoi, quand, et depuis où ?

Utopios® Tous droits réservés

CloudTrail : le journal des appels d'API

Sur AWS, **tout** passe par un appel d'API : un clic dans la console, une commande dans CloudShell, un déploiement Terraform. **CloudTrail** enregistre chaque appel sous la forme d'un **événement** JSON. Les champs qu'un enquêteur lit en premier :

```
eventTime          quand        2026-10-26T14:03:12Z
userIdentity.arn   qui          arn:aws:iam::…:user/…
sourceIPAddress    d'où         l'adresse IP de l'appelant
userAgent          avec quoi    console, CloudShell, Terraform…
eventName          quoi         AuthorizeSecurityGroupIngress
errorCode          résultat     absent si succès, AccessDenied sinon
```

- **Historique des événements** (*Event history*) : actif d'office, gratuit, **90 jours**. C'est lui que vous interrogez à l'exercice 4.
- **Trail** : copie les événements en continu vers un bucket S3. Il apporte la **conservation longue** et les **alertes automatiques**. C'est un réglage du compte, posé une fois par l'équipe sécurité.

Utopios® Tous droits réservés

Ce que le journal ne voit pas

Deux familles d'opérations, sur les deux clouds :

	Gérer les ressources	Utiliser leur contenu
Exemples	créer un bucket, ouvrir un port	déposer un fichier, lire un secret
AWS	événements de **gestion** (*management events*) : enregistrés d'office	événements de **données** (*data events*) : à activer, **facturés**
Azure	**plan de contrôle** : journal d'activité, 90 jours, d'office	**plan de données** : journaux de ressource, à activer

- Dans l'historique CloudTrail, vous verrez `CreateBucket` et `PutBucketPolicy`, mais **pas** le dépôt du fichier dans le bucket.
- Mesuré sur Azure (bonus de l'exercice 4) : le journal d'activité ne contient **ni la lecture d'un secret, ni l'écriture d'un blob**. Résultat : `0`.

💰 Les événements de données s'activent de façon **ciblée** (un bucket de données sensibles), jamais « partout, par précaution ».

Ce qui n'est pas journalisé ne pourra jamais être enquêté.

Utopios® Tous droits réservés

✏️ Exercice 4 — Qui a fait quoi ?

Fichier : `exercices/15-cl-secu-2j/exercice-4-qui-a-fait-quoi.md` — 35 min — difficulté 2/5

Vous êtes l'enquêteur. À partir de votre seul nom d'utilisateur :

1. listez vos actions d'hier qui ont **modifié** quelque chose : `CreateSecurityGroup`, `AuthorizeSecurityGroupIngress`, `CreateBucket`, `PutParameter`… ;
2. isolez l'ouverture du port 22 au monde et lisez l'événement complet : quand, qui, depuis quelle adresse IP, avec quel outil ;
3. élargissez à tout le compte : qui a ouvert des règles de groupes de sécurité depuis deux jours ?

Bonus Azure : votre journal d'activité, et ce qui **n'y figure pas**.

⏱️ Les événements apparaissent avec **5 à 15 minutes** de délai : les actions d'hier sont toutes disponibles.

Utopios® Tous droits réservés

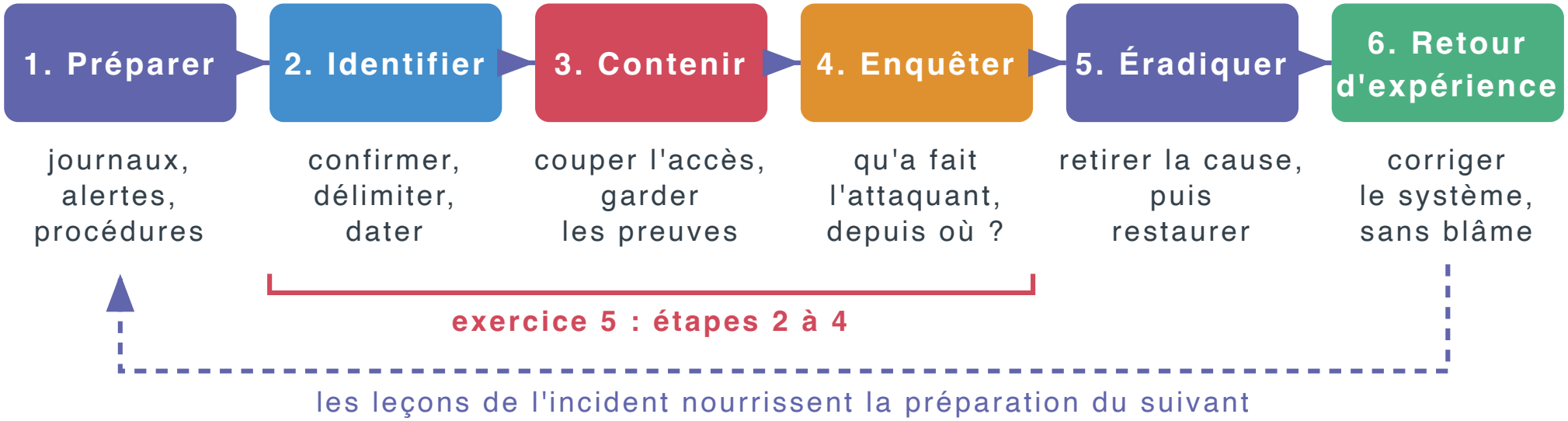
2. Réagir

Quand l'alarme sonne : une méthode, pas de la panique

Utopios® Tous droits réservés

La réponse à incident en six étapes

Un **incident de sécurité** menace la confidentialité, l'intégrité ou la disponibilité d'un système : une clé volée, un serveur compromis. Cadre inspiré du guide du **NIST**, l'organisme de normalisation américain :



Six étapes, dont la dernière nourrit la première

Deux règles d'or : **contenir d'abord, comprendre ensuite** ; **désactiver, ne pas supprimer**, tant que l'enquête n'est pas terminée.

Utopios® Tous droits réservés

Contenir sans détruire

Contenir, c'est empêcher toute nouvelle utilisation de l'accès compromis, **sans effacer les preuves** dont l'enquête a besoin. Extrait de l'exercice 5 :

```
# [AWS CloudShell]
aws iam update-access-key --user-name "$VICTIME" --access-key-id "$CLE" --status Inactive
aws iam attach-user-policy --user-name "$VICTIME" --policy-arn arn:aws:iam::aws:policy/AWSDenyAll
```

- **Désactiver** (`Inactive`) est **réversible** et conserve la clé et son historique. On ne la supprime qu'à l'étape d'éradication.
- `AWSDenyAll` est une politique gérée par AWS qui **refuse tout** : elle neutralise les autres accès éventuels de l'utilisateur.
- **Vérifier** : l'« attaquant » réessaie, et doit recevoir `InvalidClientTokenId`. Un confinement ne se suppose pas, il se prouve.
- **Agir depuis une autre identité**, protégée par la MFA, jamais avec l'identité compromise.

Azure (bonus) : la clé d'un compte de stockage ouvre tout son contenu. On la **renouvelle** (*rotation*) : l'ancienne valeur cesse de fonctionner.

Utopios® Tous droits réservés

La vraie solution : pas de clé longue durée

Une clé d'accès IAM reste valable **jusqu'à sa suppression** : elle finit dans un dépôt Git, un fichier `.env`, une capture d'écran. La meilleure surveillance ne vaut pas l'absence de secret à voler. Les solutions sans clé fournissent des **identifiants temporaires**, qui expirent d'eux-mêmes :

Qui a besoin d'un accès ?	Solution sans clé
Instance EC2, fonction Lambda	un **rôle IAM** attaché à la ressource
VM, App Service sur Azure	une **identité managée**, créée et gérée par Azure
Pipeline CI/CD qui déploie	la **fédération OIDC** (*OpenID Connect*)

```
job CI/CD ⟶ présente un jeton signé : « projet X, branche main »
AWS STS ou Entra ID ⟶ vérifie la signature et les conditions du rôle
job CI/CD ⟵ reçoit des identifiants temporaires, valables environ une heure
```

Aucun secret stocké dans les variables du pipeline : **rien à faire fuiter**.

Utopios® Tous droits réservés

✏️ Exercice 5 — Une clé a fuité

Fichier : `exercices/15-cl-secu-2j/exercice-5-cle-fuitee.md` — 45 min + 20 min après le déjeuner — difficulté 3/5

Chacun **fabrique sa propre fuite**, sans danger : un utilisateur IAM de test, **sans aucun droit**, et sa clé, qui joue l'attaquant.

1. **Préparer** : l'attaquant découvre à qui est la clé (`GetCallerIdentity` réussi), puis échoue à lister les buckets : `AccessDenied`.
2. **Contenir** : clé désactivée, politique `AWSDenyAll`.
3. **Vérifier** : l'attaquant réessaie et reçoit `InvalidClientTokenId`.
4. **Enquêter** : CloudTrail par identifiant de clé : ce qu'a fait l'attaquant, et depuis quelle adresse IP. CloudTrail met **5 à 15 min** : on termine l'enquête à **13h30**.

⚠️ Le bloc « attaquant » **remplace vos identifiants** dans CloudShell. Les blocs suivants commencent par cette ligne, qui vous rend vos droits :

```
unset AWS_ACCESS_KEY_ID AWS_SECRET_ACCESS_KEY AWS_SESSION_TOKEN
```

Bonus Azure : la clé d'un compte de stockage a fuité, rotation de `key1`.

Utopios® Tous droits réservés

3. Surveiller

Les robots d'Internet ne nous ont pas attendus

Utopios® Tous droits réservés

GuardDuty : le détecteur de menaces

GuardDuty analyse en continu, sans agent ni règle à écrire, les journaux du compte (appels d'API, requêtes DNS, flux réseau) et lève des **alertes qualifiées** (*findings*). Une alerte réelle du compte de la formation :

```
type       UnauthorizedAccess:EC2/SSHBruteForce     (Catégorie:Ressource/Comportement)
gravité    2 sur 10 : fréquent ; une exfiltration de données serait notée 8
titre      42.101.43.119 is performing SSH brute force attacks against i-04f13…
```

- Des robots essaient des mots de passe sur les instances dont le **port 22 est ouvert au monde** : c'est l'erreur de l'exercice 2, **mesurée** dans ce compte.
- Une gravité basse ne veut pas dire « rien à faire » : l'alerte révèle une surface d'attaque inutilement large.

Azure : **Microsoft Defender for Cloud** évalue la posture (recommandations, *secure score*) et, avec ses plans payants, détecte les menaces.

Utopios® Tous droits réservés

L'audit express : mesurer la posture

Un outil de **posture de sécurité** (*CSPM*, *Cloud Security Posture Management*) évalue le compte contre un référentiel reconnu, ici le **CIS AWS Foundations Benchmark**. La démo en est une version miniature : **10 contrôles**, en lecture seule. Quelques-uns :

CIS	Contrôle	Pourquoi
1.10	MFA pour tous les utilisateurs console	sinon, un compte ne tient qu'à son mot de passe
3.1	un trail CloudTrail multi-régions	sans lui : 90 jours seulement, aucune alerte
2.1.4	blocage de l'accès public S3 au niveau du compte	protège tous les buckets d'un coup
5.2	aucun groupe n'ouvre SSH (22) à tout Internet	GuardDuty vient de montrer pourquoi

Mesuré sur le compte de la formation : **2 à 3 contrôles conformes sur 10**. Un score est un **thermomètre**, pas une note : on priorise par **gravité** et par **effort**.

À grande échelle : **AWS Security Hub**, **Prowler** (libre), **Defender for Cloud** appliquent des centaines de contrôles.

Utopios® Tous droits réservés

💻 Démo — Surveiller : GuardDuty et audit express

Fichier : `demos/15-cl-secu-2j/demo-surveiller-audit-express.md` — 30 min + 20 min de discussion

1. **Ce que voit GuardDuty** : les dix dernières alertes du compte, et ce qu'elles disent de nos erreurs.
2. **L'audit express** : le script `audit-express.sh`, 10 contrôles numérotés comme le benchmark CIS, puis la **liste** des éléments concernés.
3. **Le rapport d'audit**, par binômes, en 10 minutes, pour le responsable du compte :
   - le score global ;
   - les **3 constats prioritaires** : risque concret, correction, effort ;
   - un constat **acceptable** dans une formation, et pourquoi.

Tout est en **lecture seule** : vous pourrez rejouer la démo vous-même. Ne corrigez rien : les réglages du compte appartiennent à son responsable.

Utopios® Tous droits réservés

4. Survol

Conformité, DevSecOps, alertes automatiques

Utopios® Tous droits réservés

La conformité ne se déclare pas, elle se prouve

Être **conforme**, c'est respecter un **référentiel**. L'auditeur demande des **preuves**, et c'est l'admin cloud qui les produit.

Référentiel	Nature	Pour l'admin cloud
RGPD	loi européenne sur les données personnelles	savoir où sont les données, qui y accède, combien de temps on les garde
ISO 27001	norme internationale : certification d'une **organisation**	fournir les preuves : revue des accès, journaux, changements
SecNumCloud	qualification de l'ANSSI : une **offre** cloud	choisir une offre qualifiée quand le contexte l'exige
CIS Benchmarks	guides de configuration vérifiables	contrôler le compte, comme l'audit express

Une preuve **automatique** (un script, un journal, un rapport daté) vaut mieux qu'une capture d'écran : elle se rejoue à l'identique à chaque audit.

Utopios® Tous droits réservés

Le RGPD pour l'admin cloud

Le **RGPD** (Règlement général sur la protection des données, 2018) encadre le traitement des données personnelles des personnes situées dans l'Union européenne. Une **donnée personnelle** permet d'identifier une personne : nom, e-mail, identifiant, **adresse IP**.

- **Vos journaux en contiennent** : un événement CloudTrail porte l'identité et l'adresse IP de l'appelant. Il leur faut une **durée de conservation** justifiée et un **accès restreint**.
- **Localisation** : la région est un paramètre (`eu-west-3`, Paris). Le RGPD encadre les transferts hors de l'Union européenne.
- **Rôles** : votre entreprise est **responsable du traitement** ; AWS ou Microsoft est **sous-traitant**, lié par un contrat.
- **Violation de données** : notification à la **CNIL** sous **72 heures**. Sans journaux, impossible de dire ce qui a fui.

Votre rôle n'est pas juridique : **savoir où sont les données, qui y accède, combien de temps on les garde**, et pouvoir le montrer.

Utopios® Tous droits réservés

ISO 27001 et SecNumCloud

ISO 27001 : la norme internationale de management de la sécurité de l'information. Une organisation **certifiée** prouve qu'elle identifie ses risques, applique des mesures, les mesure et s'améliore. L'auditeur demande à l'admin cloud :

- la **revue des accès** : qui est administrateur, et est-ce encore justifié ?
- les **journaux** : les actions sont-elles tracées, protégées, conservées combien de temps ?
- la **gestion des changements** : comment une modification arrive-t-elle en production ?

SecNumCloud : une **qualification** délivrée par l'**ANSSI** (Agence nationale de la sécurité des systèmes d'information) à une **offre** cloud. Exigences renforcées, et **protection contre les lois extra-européennes** (par exemple le *Cloud Act* américain). Attendue pour les données sensibles de l'État et de nombreux marchés publics.

⚠️ Être hébergé **en France** ne suffit pas : les régions standard d'AWS et d'Azure, même à Paris, **ne sont pas qualifiées** SecNumCloud.

Utopios® Tous droits réservés

DevSecOps : refuser l'erreur avant le déploiement

Hier, vous avez corrigé **à la main** un port 22 ouvert et vérifié un bucket. Ces erreurs auraient pu être **refusées avant d'exister**, en scannant le code.

```
code ──► commit ──► pipeline CI/CD ──► déploiement ──► production
◄── plus le contrôle est tôt, moins l'erreur coûte
```

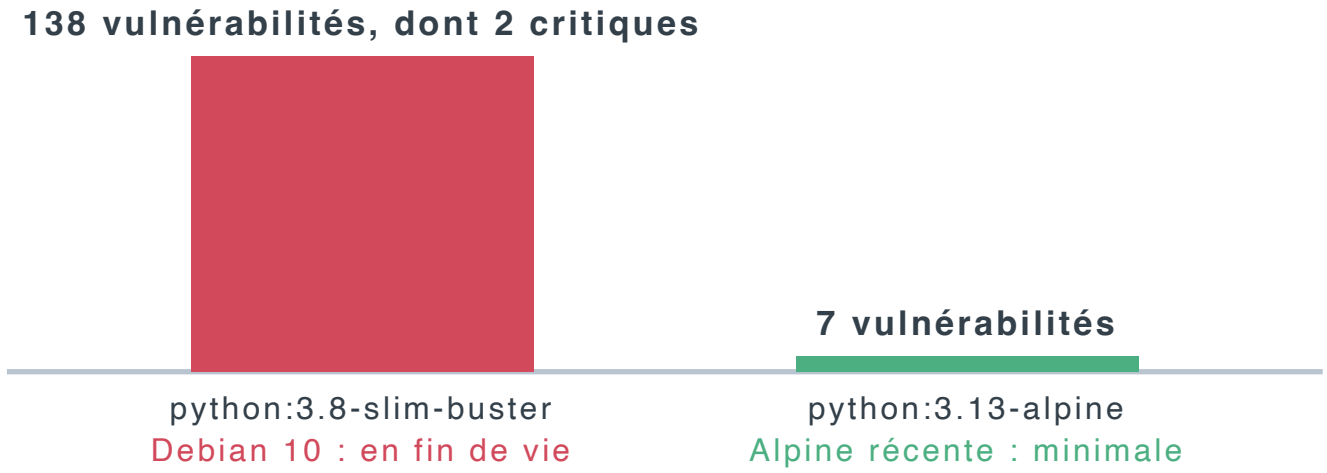
- **Shift-left** (« décaler vers la gauche ») : placer les contrôles de sécurité le plus tôt possible.
- **DevSecOps** : ces contrôles tournent **automatiquement à chaque changement**, dans le pipeline, comme les tests.

Trois familles de scans, deux outils libres :

- les **mauvaises configurations** du code Terraform → **checkov**, **trivy** ;
- les **secrets** oubliés dans un dépôt (jetons, clés, mots de passe) → **trivy** ;
- les **vulnérabilités connues** (*CVE*) des images de conteneurs → **trivy**.

Utopios® Tous droits réservés

Scanner les images : la base compte



Vulnérabilités connues comptées par trivy (mesure de test ; les nombres évoluent chaque jour, l'ordre de grandeur reste)

- **En fin de vie** : des failles critiques qui ne seront **jamais corrigées**. On change d'image de base.
- **Minimale et maintenue** : moins de logiciels, donc moins de failles ; on **reconstruit** l'image régulièrement.
- Dans un pipeline, on **bloque** sur tout secret et sur les failles critiques corrigeables. Un secret trouvé dans un dépôt est **compromis** : on le révoque d'abord.

Utopios® Tous droits réservés

Alertes automatiques : être prévenu

Un journal que personne ne lit ne protège personne. Les deux clouds savent **déclencher une action** quand un événement correspond à une condition :

```
AWS     appel d'API ──► trail CloudTrail ──► EventBridge (règle + motif) ──► SNS ──► e-mail
        alerte GuardDuty ──────────────────► EventBridge ──► Lambda : correction automatique
Azure   journal d'activité ──► alerte (condition) ──► groupe d'actions ──► e-mail, SMS, webhook
        Defender for Cloud ──► alertes de sécurité ──► e-mail aux responsables
```

- **EventBridge** filtre les événements avec un **motif** : par exemple, « ouverture d'un port à `0.0.0.0/0` ». **SNS** prévient les abonnés.
- Sans **trail**, EventBridge ne reçoit pas les appels d'API : c'est une raison de plus pour le contrôle CIS 3.1.
- Une bonne alerte est **rare et actionnable** : trop d'alertes, et plus personne ne les lit.

Utopios® Tous droits réservés

🧹 Nettoyage obligatoire

Fichier : `exercices/15-cl-secu-2j/nettoyage.md` — 10 min — **à faire avant de partir**

Une ressource oubliée coûte de l'argent et élargit la surface d'attaque. Vous supprimez **tout** ce que vous avez créé pendant les deux jours, et **uniquement** cela : chaque ressource visée porte votre nom.

Où	Ce qui est supprimé
AWS CloudShell	l'utilisateur `secu-…-fuite` et ses clés, le paramètre secret, le bucket et son contenu, le groupe de sécurité
Azure Cloud Shell (si bonus)	le NSG et le compte de stockage ; votre groupe de ressources est conservé

Chaque partie se termine par une **vérification** qui doit afficher `OK`. Les blocs sont rejouables sans risque.

Utopios® Tous droits réservés

Synthèse du module : deux jours, une posture

Jour 1 — Protéger

- Responsabilité partagée : votre part
- Moindre privilège, prouvé par simulation
- SSH jamais ouvert à tout Internet
- Stockage chiffré, jamais public
- Secrets dans un coffre, jamais en clair

Jour 2 — Détecter et réagir

- Journaliser : CloudTrail, journal d'activité
- Réagir : contenir sans détruire
- Pas de clé longue durée
- Surveiller : GuardDuty, audit CIS
- Prouver : RGPD, ISO 27001, SecNumCloud

Automatiser · superviser · sécuriser, et pouvoir le prouver

Le module CL-SECU en une image

Le réflexe à emporter : **on ne protège que ce que l'on voit, et on ne prouve que ce que l'on mesure.** Et la meilleure clé d'accès reste celle qui n'existe pas.

Utopios® Tous droits réservés

Quiz — questions 1 & 2

Q1. L'historique CloudTrail conserve déjà 90 jours d'événements, sans aucun réglage. Qu'apporte en plus un **trail** vers un bucket S3 ? Donnez deux apports.

Q2. Vous cherchez qui a déposé hier un fichier dans un compte de stockage Azure : le journal d'activité ne montre rien. Pourquoi ? Quel est l'équivalent de ce piège sur AWS ?

Utopios® Tous droits réservés

Quiz — questions 3 & 4

Q3. Une clé d'accès a fuité. Pourquoi la **désactiver** plutôt que la supprimer tout de suite ? Comment prouver que le confinement fonctionne ?

Q4. Quelle est la meilleure protection contre la fuite d'une clé d'accès ? Donnez la solution adaptée pour une instance EC2, pour une VM Azure et pour un pipeline CI/CD qui déploie sur AWS.

Utopios® Tous droits réservés

Quiz — questions 5 & 6

Q5. GuardDuty remonte des alertes `UnauthorizedAccess:EC2/SSHBruteForce` dans le compte de la formation. Que signifient-elles, quelle mauvaise configuration les rend possibles, et comment la corriger ?

Q6. Un collègue affirme : « Nos données sont dans la région AWS de Paris, donc nous sommes conformes au RGPD et à SecNumCloud. » Qu'est-ce qui est juste, et qu'est-ce qui est faux ?

Utopios® Tous droits réservés

Fin du module CL-SECU

Protéger, détecter, réagir

Merci pour ces deux jours. Avant de partir : **nettoyage vérifié**, avec `OK` partout.

Prochain module, CL-SOFT : communiquer comme un professionnel.

Votre rapport d'audit de cet après-midi en était un premier exercice.

Utopios® Tous droits réservés